SAFETY 4.0 BOOTCAMP · YAZILIM MÜHENDİSLİĞİ GÜNCEL KONULAR

MiR250 Otonom Mobil Robot Safety 4.0 Lab Raporu (LAB 1–4)

Siber güvenlik ve emniyet

Ad Soyad Betül Altunyuva
235542020

Grup Gece-B

Tarih 23.10.2026

0. Makine tanımı

MiR250, Mobile Industrial Robots A/S'nin ürettiği, fabrika içinde yük taşıyan otonom mobil robottur (AMR). İnsanlarla aynı koridoru paylaşır, haritayı kendisi çıkarır ve rotasını kendisi bulur. Bu rapor, MiR250'nin bir üretim tesisinde üretim hattına malzeme taşıdığı varsayımına göre yazılmıştır.

Örnek kullanım senaryosu: MiR250 depodan montaj hattına parça kasası taşır. Rotası, forklift ve yaya trafiğinin olduğu ortak koridorlardan geçer. Görevler fabrika Wi-Fi'ı üzerinden MiR Fleet yazılımıyla verilir. Bakım için üretici servisi uzaktan bağlanabilir.

Teknik özellikler

Özellik	Değer
Boyut (U × G × Y)	800 × 580 × 300 mm
Ağırlık	97 kg
Azami yük	250 kg
Azami hız (tam yükte, düz zemin)	2,0 m/s (7,2 km/h)
Batarya	Li-ion, 47,7 V, 1,63 kWh
Çalışma süresi (tam yükte)	13 saat
Kullanım ortamı	Sadece kapalı alan, IP21, 5–40 °C
Uyumluluk (üretici beyanı)	CE, EN 1525, ANSI B56.5, ANSI R15.08; EMC: EN 61000-6-2/-4

Kaynak: MiR250 Specifications, 2023-06-28

Bileşen listesi

Grup	Bileşen	Görevi
Emniyet	2 × SICK nanoScan3 emniyet lazer tarayıcısı (ön ve arka)	Robot çevresinde 360° koruma alanı; insan algılanınca durdurur
Emniyet	SICK emniyet kontrolcüsü (Safety PLC)	Tarayıcı ve acil stop sinyallerini işler, motorların gücünü keser
Emniyet	Acil stop butonları + 1 harici (yardımcı) acil stop girişi	Elle durdurma
Emniyet	Emniyet I/O: 6 giriş, 6 çıkış	Üst modül ve harici emniyet ekipmanı bağlantısı
Algılama	2 × Intel RealSense D435 3D kamera	Yüksekteki engelleri görür (emniyet fonksiyonu değil, navigasyon yardımı)
Algılama	8 × yakınlık sensörü	Robotun hemen dibindeki engelleri algılar
Kontrol	Robot bilgisayarı (Linux, ROS tabanlı MiR Robot Software)	Harita, rota, görev yönetimi
Ağ	Dahili Wi-Fi yönlendirici (2,4 / 5 GHz) + dahili PC Wi-Fi adaptörü	Fleet ve web arayüzü bağlantısı
Ağ	1 × Ethernet (M12, Modbus)	Kablolu bağlantı, servis

Grup	Bileşen	Görevi
Ağ	GPIO: 4 dijital giriş, 4 dijital çıkış	Kapı, asansör vb. ile haberleşme
Arayüz	Web arayüzü (port 80, robot üzerindeki Apache sunucusu)	Robotu tarayıcıdan yönetme
Yazılım	MiR Fleet	Birden çok robotu merkezden yönetme
Güç	MiR Charge 48V şarj istasyonu (CAN ile haberleşir)	Otomatik şarj
Sinyal	Köşelerde 8 sinyal ışığı, hoparlör	Yayaları uyarma

LAB 1 — Safety Architecture (Çıktı: Safety Function Map → EP 03)

MiR250'nin asıl emniyet fonksiyonu **insan algılama**dır: lazer tarayıcı koruma alanında birini görürse emniyet kontrolcüsü motorları durdurur. Bu fonksiyonun güvenilirliği, tarayıcıdaki koruma alanı boyutu ve hız sınırı gibi **dijital konfigürasyona** bağlıdır; siber risk de tam bu noktada başlar.

Föy soruları

1. **Tehlike nedir? İnsan neyden zarar görür?** Hareket eden 97 kg robot ve üstündeki 250 kg yük. Toplam kütle 350 kg'a, hız 2 m/s'ye ulaşır. Tehlikeler: yayaya **çarpma**, robotla duvar/raf arasında **sıkışma ve ezilme**, ayağın tekerlek altında kalması, devrilen ya da düşen yükün altında kalma (ISO 12100: mekanik tehlike).
2. **Safety function hangisidir?**
   - **SF1 – İnsan algılama (koruma alanı):** Tarayıcı koruma alanında engel görürse robot durur.
   - **SF2 – Acil durdurma:** Butona basılınca robot durur.
   - **SF3 – Aşırı hız önleme:** Robot, emniyet için tanımlanan hız sınırını aşamaz.
   - **SF4 – Hıza bağlı alan değişimi:** Robot hızlandıkça koruma alanı büyür, böylece durma mesafesi her zaman alanın içinde kalır.
3. **Safety-related control system nerede?** Robotun gövdesinde: iki SICK nanoScan3 tarayıcı, SICK emniyet kontrolcüsü, motor sürücülerindeki güç kesme ve acil stop butonları. Robot bilgisayarı (ROS) bu zincirin dışındadır.
4. **Normal PLC ile Safety PLC farkı nedir?** Robot bilgisayarı "nereye, ne hızla gideyim" kararlarını verir; hata yaparsa robot yanlış yere gider. Emniyet kontrolcüsü ise sadece "durmalı mıyım" sorusuna bakar. Çift kanallıdır, kendi hatalarını izler ve bir hata görürse robotu güvenli duruma geçirir.
5. **PLr / SIL neden var? Bu fonksiyon için neden önemli?** Çarpma sonucu ağır yaralanma olabilir (S2), yayalar gün boyu robotla karşılaşır (F2) ve robot arkadan ya da kör köşeden geldiğinde kaçınmak zordur (P2). Bu yüzden insan algılama ve acil durdurma için yüksek güvenilirlik gerekir. Sürücüsüz endüstriyel araç standardı ISO 3691-4 bu fonksiyonlar için tipik olarak **PL d** ister.
6. **Safe state nedir?** Robot durmuş, motorların sürüş gücü kesilmiş ve frenler devrede. Robot kendi kendine yeniden hareket etmez; emniyet alanı temizlenene veya operatör onaylayana kadar bekler.
7. **Safety function hangi dijital bağımlılıklara sahip?**
   - Tarayıcıdaki koruma alanı geometrisi ve alan setleri (konfigürasyon dosyası)
   - Emniyet kontrolcüsündeki hız sınırı ve alan geçiş mantığı
   - Emniyet kontrolcüsünün parolası
   - Robot yazılımındaki **koruma alanını susturma (muting)** bölgeleri: dar kapılardan geçerken tarayıcı geçici olarak susturulur
   - Robot bilgisayarının verdiği hız komutu ve harita (yasak ve yavaş bölgeler)
8. **Siber müdahale hangi noktadan bu fonksiyonu bozar?**
   - **Emniyet kontrolcüsünün varsayılan parolası (CVE-2020-10276):** Haziran 2020 öncesi robotlarda bu parola ile acil stop devre dışı bırakılabiliyor.
   - **Web arayüzü ve haritalar:** Bir saldırgan susturma bölgesi ekleyebilir, yavaş bölgeyi kaldırabilir ya da hızı artırabilir.
   - **Kimlik doğrulamasız ROS arayüzü (CVE-2020-10271/10272):** Robot doğrudan kontrol edilebilir.
   - **Varsayılan Wi-Fi parolası (CVE-2020-10269):** Saldırganın içeri girdiği kapı budur.

Safety Function Map

Emniyet fonksiyonu	Tetikleyen	Karar veren	Uygulayan	Güvenli durum	Gerekli PLr (ISO 3691-4)	Dijital bağımlılık
SF1 İnsan algılama	2 × nanoScan3	SICK emniyet kontrolcüsü	Motor sürüş gücü kesme + fren	Robot durur	d	Koruma alanı geometrisi, susturma bölgeleri
SF2 Acil durdurma	Acil stop butonları	SICK emniyet kontrolcüsü	Motor sürüş gücü kesme + fren	Robot durur	d	Emniyet kontrolcüsü parolası (CVE-2020-10276)
SF3 Aşırı hız önleme	Teker enkoderleri	SICK emniyet kontrolcüsü	Motor sürüş gücü kesme	Robot durur	d	Emniyet hız sınırı parametresi
SF4 Hıza bağlı alan değişimi	Enkoder hızı	SICK emniyet kontrolcüsü	Tarayıcıda alan seti seçimi	Büyük alan / dur	d	Alan setleri ve hız eşikleri

Açık soru: MiR250 kullanım kılavuzunun "Safety-related functions" bölümündeki üretici beyanı (PL ve kategori) kontrol edilip tabloya işlenmeli. Yukarıdaki PLr değerleri standartın tipik gerekliliğidir, üretici beyanı değildir.

LAB 2 — IEC 62443 Mini Workshop (Çıktı: Zone / Conduit Diagram → EP 01, EP 05)

Sistematik envanter, ilk bakışta "robot + şarj istasyonu" gibi görünen sistemde **20 varlık ve 5 dış bağlantı** çıkarıyor. Emniyet kontrolcüsü ve tarayıcılar en kritik bölgeye konur. En riskli geçiş, robotun kendi Wi-Fi erişim noktası ile üretici servisinin uzak erişimidir.

Envanter (altı kategori)

Kategori	Varlıklar	Not
1 · Donanım	Robot bilgisayarı, SICK emniyet kontrolcüsü, 2 × nanoScan3, 2 × 3D kamera, 8 yakınlık sensörü, motor sürücüleri, dahili Wi-Fi yönlendirici, MiR Charge 48V, MiR Fleet sunucusu, servis dizüstüsü	Robot içinde USB portu ve BIOS açık (CVE-2020-10277/10278)
2 · Yazılım / firmware	MiR Robot Software (Ubuntu + ROS), MiR Fleet, Apache web sunucusu, tarayıcı firmware'i, emniyet kontrolcüsü konfigürasyonu	2.10.2.1 öncesi sürümler CISA ICSA-21-280-02 kapsamında
3 · Hesaplar	Web arayüzü kullanıcıları (operatör, yönetici, servis), Fleet hesapları, emniyet kontrolcüsü parolası, Linux hesapları	Varsayılan şifreler kılavuzda yazılı (CVE-2020-10270, CVE-2020-10276)
4 · Sertifika / anahtar	Robot Wi-Fi parolası (WPA2), fabrika Wi-Fi parolası, Fleet–robot bağlantı bilgileri, uzak erişim (VPN) anahtarı	Robot Wi-Fi ağ adı tahmin edilebilir, parolası kılavuzda (CVE-2020-10269)
5 · Dış bağlantı	(1) Robot Wi-Fi erişim noktası, (2) fabrika Wi-Fi'ı, (3) Fleet sunucusu, (4) üretici servisinin uzak erişimi, (5) GPIO/Modbus ile kapı-asansör bağlantısı	Ethernet portu robot üzerinde fiziksel olarak erişilebilir
6 · Kritik veri akışı	Harita ve bölge (susturma / yavaş / yasak) dosyaları, görev komutları, emniyet konfigürasyonu, yazılım güncellemeleri, loglar	Harita dosyası dolaylı olarak emniyeti etkiler

Görev A — Bölgeler ve geçişler

1. Hangi varlıklar aynı bölgede?

Zone	İçindekiler	Kritiklik
Z0 · Kurumsal IT	ERP, e-posta, ofis bilgisayarları	Düşük
Z1 · DMZ	Uzak erişim jump server'ı, güncelleme sunucusu	Orta
Z2 · Filo yönetimi	MiR Fleet sunucusu, operatör tabletleri, fabrika robot Wi-Fi'ı (ayrı SSID)	Yüksek

Zone	İçindekiler	Kritiklik
Z3 · Robot kontrol	Robot bilgisayarı (ROS), web arayüzü, dahili Wi-Fi yönlendirici, kameralar	Yüksek
Z4 · Robot emniyet	SICK emniyet kontrolcüsü, 2 × nanoScan3, acil stoplar, motor güç kesme	En yüksek

2. Safety PLC'yi hangi bölgeye koydunuz? Neden? Emniyet kontrolcüsü ayrı bir bölgeye (Z4) konur, çünkü insanı koruyan tek katmandır. Robot bilgisayarı ele geçirilse bile emniyet kontrolcüsüne ulaşılamamalıdır. Bugünkü tasarımda emniyet kontrolcüsü robotun iç ağında ve varsayılan parolayı taşıyabilir (CVE-2020-10276). Bu yüzden Z3 ile Z4 arasındaki geçiş en kritik conduit'tir.

3. Conduit'ler nerede? Her geçişte ne kontrol edilecek?

Conduit	Geçiş	Kontrol
C1	Z0 → Z1	Güvenlik duvarı; IT'den OT'ye doğrudan trafik yok
C2	İnternet (üretici servisi) → Z1	VPN + MFA, kişisel hesap, varsayılan kapalı, oturum kaydı
C3	Z1 → Z2	Sadece jump server'dan Fleet'e, sadece gerekli portlar
C4	Z2 → Z3 (Wi-Fi)	WPA2/WPA3-Enterprise, robotun kendi erişim noktası kapalı ya da parolası değiştirilmiş; ROS portları dışarıya kapalı
C5	Z3 → Z4	Emniyet konfigürasyonu sadece yerinde, kişisel parolayla ve değişiklik kaydıyla yazılabilir; robot bilgisayarı sadece "alan seti seç" sinyali gönderebilir
C6	Robot Ethernet / USB portu	Fiziksel kapak, USB boot kapalı, BIOS parolası

Görev B — Uzak erişim kararı

Karar	Seçim	Nedeni
Aracı?	Jump server	Üretici servisi robota ya da Fleet'e doğrudan ulaşmaz; tüm erişim DMZ'deki tek noktadan geçer ve orada kesilebilir.
Tünel?	VPN	Trafik şifrelenir; Fleet ve robot internete hiç açılmaz.
Kimlik?	MFA	Kılavuzda yazan ya da sızan bir parola tek başına içeri girmeye yetmez.
Hesap?	Kişisel	Kimin ne yaptığı izlenebilir; işten ayrılan teknisyenin hesabı tek başına kapatılabilir.
Kayıt?	Tam oturum kaydı	Bir olay olursa "emniyet konfigürasyonuna kim dokundu" sorusu cevaplanabilir; CRA bildirimi için kanıt olur.
Zamanlama?	Varsayılan kapalı	Erişim sadece talep üzerine ve süre sınırlı açılır; geri kalan zamanda saldırı yüzeyi sıfırdır.

LAB 3 — Threat & Risk + Risk Matrix (Çıktı: Risk Register → EP 04)

Amacımız, LAB 2'de bulunan açık kapıları LAB 1'deki emniyet fonksiyonlarıyla eşleştirip hangi riskin önce ele alınacağına karar vermek. Her senaryo beş parçadan oluşur ve **fiziksel bir sonuçla** biter. Puan = L × S × E (her biri 1–3). Kural: S = 3 olan senaryo, skoru düşük olsa bile S3 bayrağı alır.

Puanlar, mevcut durumu (varsayılan parolalar değiştirilmemiş, robot internete erişilebilir bir ağda) temsil eder. Önlemli hâl LAB 4'te hesaplanır.

Risk Register

#	Senaryo (profil → kapı → eylem → zincir → fiziksel sonuç)	L	S	E	Skor	Bant	S3
R-01	Fırsatçı dış saldırgan → varsayılan parolalı robot Wi-Fi'ı → web arayüzünden koruma alanını küçültür / hız sınırını yükseltir → robot yayayı zamanında algılayıp duramaz → koridordaki çalışana çarpar, ağır yaralanma	3	3	3	27	Kritik	S3
R-02	Meraklı içeriden → paylaşılan web arayüzü hesabı → dar bir geçişe gereksiz susturma (muting) bölgesi tanımlar → robot o bölgede tarayıcıyı susturur → orada duran çalışanı raf ile robot arasında sıkıştırır, ezilme	2	3	2	12	Yüksek	S3
R-03	Fırsatçı dış saldırgan → Haziran 2020 öncesi robotta varsayılan emniyet kontrolcüsü parolası (CVE-2020-10276) → acil durdurma fonksiyonunu devre dışı bırakır → operatör acil stopa bastığında robot durmaz → çarpma / ezilme	1	3	2	6	Orta	S3
R-04	Fırsatçı dış saldırgan → web sunucusu (port 80) aşırı yük (CVE-2020-10280) → arayüz yanıt veremez hale gelir → operatör robotu izleyemez/durduramaz, panik → kontrolsüz hareket, çarpma riski	2	2	3	12	Yüksek	—
R-05	Tedarik zinciri → üretici servisinin uzak erişimi → güncelleme ile hatalı harita/bölge dosyası yüklenir → yasak bölge kalkar, robot insan yoğun alana girer → çarpma	2	3	1	6	Orta	S3

Föy soruları

1. **En yüksek öncelikli senaryonuz hangisi? Neden?** R-01 (skor 27, Kritik). Çünkü üç çarpan da en yüksek: kapı kolay istismar edilir (varsayılan parola, L3), sonuç ağır yaralanmadır (S3) ve robotun Wi-Fi'ı sürekli açıktır (E3). Hem en olası hem en ağır senaryo budur.
2. **S = 3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?** R-03 (skor 6) ve R-05 (skor 6). Çarpma işlemi şiddeti saklar: skor düşük ama yine bir insan ağır yaralanır. Bu senaryolar S3 bayrağı alır, ayrı bir yönetim listesinde tutulur ve en az bir önlem ya da yazılı kabul kararı olmadan kapatılmaz.

Altın kural kontrolü: Tüm senaryolar fiziksel sonuçla bitti (çarpma, ezilme). "Veri çalındı" ile biten, yani emniyet fonksiyonuna dokunmayan senaryolar bu Safety 4.0 Register'a girmez; onlar genel siber risk kaydına gider.

LAB 4 — Secure Remote Access (Çıktı: Secure Architecture → EP 02, EP 06)

Güvenli mimari iki katmandan oluşur ve ikisi de şarttır. **Erişim güvenliği** saldırganın içeri girmesini zorlaştırır ve L ile E puanlarını düşürür. **Emniyet bağımsızlığı** ise saldırgan girse bile insanı korur ve S puanını düşürebilen tek önlemdir.

Görev A — Mevcut → Hedef

	MEVCUT (savunmasız)	HEDEF (beş ilkeyle)
Ara nokta	Robot ve Fleet, fabrika ağından ve robotun kendi Wi-Fi'ından doğrudan erişilebilir	Uzak erişim yalnızca DMZ'deki jump server üzerinden; robotun kendi erişim noktası devre dışı
Kişisel hesap	Web arayüzü ve emniyet kontrolcüsü varsayılan, paylaşılan parolalarla	Her kullanıcıya kişisel hesap; varsayılan parolalar ilk kurulumda değiştirilir
İkinci faktör	Yok	Uzak erişim ve yönetici hesapları için MFA
Varsayılan kapalı	Servis erişimi sürekli açık	Erişim talep üzerine açılır, süre dolunca kendiliğinden kapanır
Oturum kaydı	Kimin ne değiştirdiği bilinmiyor	Tüm uzak oturumlar ve emniyet konfigürasyonu değişiklikleri kayıt altında

Ek sertleştirme: robot yazılımı güncel sürüme (en az 2.10.2.1) yükseltilir, robot için ayrı bir Wi-Fi ağı (WPA2/WPA3-Enterprise) kurulur, USB'den açılış kapatılır ve BIOS parolası verilir.

Görev B — Functional safety köprüsü

1. **Saldırgan tüm önlemlere rağmen içeri girerse emniyet fonksiyonu etkilenir mi? Neden?** Bugünkü tasarımda evet. Koruma alanı boyutu, susturma bölgeleri ve hız sınırı robot bilgisayarı üzerinden değiştirilebilen dijital ayarlardır. Emniyet kontrolcüsü mekanik olarak ayrı olsa da konfigürasyonu ağ üzerinden erişilebilir olduğu sürece siber bir müdahale insanı koruyan fonksiyonu zayıflatabilir.
2. **Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİM (çözüm değil):**
   - Emniyet konfigürasyonu (koruma alanları, hız sınırı, acil stop mantığı) robot bilgisayarından ve ağdan **değiştirilememelidir**; yalnızca yerinde, yetkili kişiyle değiştirilebilmelidir.
   - Robot bilgisayarı emniyet kontrolcüsüne yalnızca önceden doğrulanmış alan setlerinden birini **seçme** isteği gönderebilmeli; yeni alan **tanımlayamamalıdır**.
   - Susturma bölgeleri emniyet sorumlusunun onayı olmadan aktif olmamalı ve her değişiklik kayıt altına alınmalıdır.
   - Emniyet konfigürasyonundaki her değişiklik tespit edilebilmeli (bütünlük kontrolü) ve değişiklik sonrası robot yeniden emniyet doğrulamasından geçmeden çalışmamalıdır.

Tarafsızlık notu: Bu bölüm gereksinimi tanımlar; teknik çözümün seçimi firmaya aittir.

R-01 için doğal ve artık risk

Durum	L	S	E	Skor	Bant	S3
Bugün (mevcut önlemler)	3	3	3	27	Kritik	Sürer
+ Erişim önlemleri (jump server, MFA, varsayılan kapalı, parolalar değişti)	1	3	2	6	Orta	Sürer
+ Emniyet bağımsızlığı (siber yol emniyet konfigürasyonuna ulaşamaz)	1	1	2	2	Düşük	Kalkar

Erişim önlemleri L ve E'yi düşürür ama S3 bayrağını kaldırmaz. Bayrağı yalnızca emniyet tasarımı kaldırır.

Kaynaklar

- MiR250 Specifications (Mobile Industrial Robots, 2023-06-28)
- MiR250 ürün dokümanları — Mobile Industrial Robots
- CISA ICSA-21-280-02 — Mobile Industrial Robots Vehicles and MiR Fleet Software
- CVE-2020-10269
- CVE-2020-10270
- Safety 4.0 Bootcamp, LAB 1–4 föyleri ve LAB 3 "Threat & Risk Lab" sunumu (INSPECCO × Kriptarium)

Bu rapor bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez.